TEMPLATE P58 · ANNUAL AI AUDIT PLAN

Annual AI audit plan

Builds the audit universe, prioritises each unit by risk, allocates the year's engagements with their capacity and records the approval and the quarterly degree of completion.

Fernando García Varela Version 0.1 (working draft) 19-09-2026 Draft for review

IN THIS DOCUMENT

01 Instructions for use

02 Identification

03 Audit universe

04 Priority score

05 Engagement plan for the year

06 Capacity and resources

07 Approval of the plan and limitations

08 Monitoring of completion

09 Quality criteria

10 Approval and verification

11 Version control

Legal notice and disclaimer. SEVEN-G is a reference methodological framework provided "as is" and for information purposes only. It does not constitute legal, regulatory, financial or professional advice, nor does it guarantee compliance with any law or standard. References to general regulation (such as the EU AI Act, the GDPR, DORA or NIS2), to technical standards and to regulation specific to each sector or jurisdiction may be incomplete, may not apply to a particular case or may become out of date as a result of regulatory changes, interpretations or supervisory positions after their consultation date. **Each organisation that uses SEVEN-G is solely responsible for identifying the regulation that applies to it, verifying that it is current and certifying its own regulatory compliance**, with the appropriate qualified advice. This methodology is a generic, free aid shared with the community so that nobody has to start from scratch; each person or organisation can and should adapt it to its own use. It must not be inferred that its legally sensitive parts have been reviewed by legal counsel: those reviews, for each company or sector, are the ultimate responsibility of the company, consultant or organisation that uses it. Although every effort is made to keep it up to date, some regulation may have changed without being reflected here. To the fullest extent permitted by law, the author accepts no responsibility whatsoever for the effects of its application in any organisation or for its full applicability. The methodology does not grant certification of any kind. The author accepts no liability for any use made of this content or for any decisions taken on the basis of it. The data, figures, companies and cases in the examples are fictitious or illustrative.

Why it matters. The third line cannot audit everything every year: the plan decides where to look and where not to. Without a complete universe and an explicit score, coverage depends on the auditor's availability and the highest-risk systems may go unaudited for years. The plan shows the board committee what remains uncovered and obliges it to decide whether to increase resources or accept that risk. It is also the internal audit programme required by ISO/IEC 42001 (clause 9.2).

01

Instructions for use

Aspect	Guidance
When it is used	It is prepared once a year, before the start of the financial year, using the results of the previous year's C5 review. It is updated when a High-priority system joins the universe or an unplanned audit takes place (S1 incident, request from an authority).
Who completes it	Internal audit (head of AI audit), with the data from T02, T01 and T09 provided by the AI Office.
Who verifies it	Internal audit's quality review checks the universe and the scores before the plan is presented.
Who decides or approves	The board committee (38 §5.3; document 30 §7.5). If AI auditing is integrated into the corporate internal audit plan, it is approved jointly or in a coordinated manner (38 §12.2).
Corporate cycle stage	Preparation after C5; approval before the start of the financial year; quarterly monitoring of its completion alongside C4 oversight.
Tool	It has no dedicated tool. The universe is extracted from T02 (inventory), T01 (use case register) and T09 (suppliers); open findings from T08. The formulas in section 4 allow it to be kept in a spreadsheet.
Reference document	Document 38 §4, §5 and §12; document 21 §10.3 (sample of *gates*); document 43 §12 (value audit).
Lite versus Enterprise	All Enterprise *gates* are verified; Lite *gates* are audited by sample (21 §10.3: at least 10 % with a minimum of three, including at least one G5). Intensity is also a scoring factor.

Completion rules:

- The universe includes **all** the units in 38 §5.1. A system that is not in the inventory cannot be scored: this is why the reconciliation of the inventory (32 §9) is a recurring test in the framework audit.
- The factor table is **for reference**. If the company adjusts it, it declares this in section 4.1 and the adjustment is approved by the board committee together with the plan.
- **High** priority is also assigned, regardless of the score, to every high-risk system in production and to every system with A3 autonomy and direct exposure.
- Between **10 % and 20 %** of capacity is reserved for unplanned audits.
- If capacity is insufficient to cover the High-priority systems, the limitation is recorded in section 7 and decided by the board committee.

02

Identification

Field	Content	Guidance
Company and perimeter		Companies and areas covered by the plan.
Financial year		Year or twelve-month period.
Plan version		1.0 on approval; 1.1, 1.2… for each approved amendment.
Head of AI audit		Name and position.
Universe cut-off date		DD-MM-AAAA. Date of extraction from T02, T01 and T09.
Relationship with the corporate internal audit plan		Integrated · Coordinated.
Factor table applied		Reference (38 §5.2) · Adjusted (describe in 4.1).
Outcome of the last framework audit		Conformant · Conformant with observations · Nonconformant, with its AUD-AAAA-NNN code.

03

Audit universe

Each unit is numbered consecutively within the plan (U01, U02…). A unit is a system, a use case, a supplier, a framework process or a cross-cutting theme (38 §5.1).

No.	Unit type	Code	Name	Source	Owner	Status or phase	Last audit (code and date)
U01	System · Use case · Supplier · Process · Theme	SIA-AAAA-NNN · IA-AAAA-NNN · T09 code · process name		T02 · T01 · T09 · Document · Risk report · T08			
U02							

No.	Unit type	Code	Name	Source	Owner	Status or phase	Last audit (code and date)
U03							
(illustrative example) **U01**	System	SIA-2026-014	Customer enquiries assistant	T02	AI Operations Owner for the customer area	In production	Never audited
(illustrative example) **U02**	Process	—	Inventory and regulatory classification	Document 32	AI Office	Operational	AUD-2026-003 · 20-11-2026

Units that must be included as a minimum:

Unit	Source	All included? (Yes · No)	If No, reason
Each AI system in development, pilot or production	T02		
Each use case with *gates* planned in the financial year	T01		
Each AI supplier with level N2 or N3	T09		
Framework processes: corporate cycle, portfolio management, inventory, risks, measurement, nonconformities, policies and literacy	Documents 01, 14, 31, 32, 33, 37 and 40		
Cross-cutting themes identified by the second line or by incidents	Risk reports; T08		

04

Priority score

4.1 Factors

Each system in the universe is scored from 1 to 3 on nine factors (38 §5.2).

No.	Factor	1	2	3
F1	Regulatory classification	Minimal risk or out of scope	Transparency obligations or Article 6.3 exception	High risk
F2	Intensity	Lite	—	Enterprise
F3	Autonomy	A0	A1	A2 or A3
F4	Exposure	Internal	Employees or customers indirectly	Customers or external persons directly
F5	Main residual risk	Low	Medium	High or Critical
F6	Incidents and nonconformities in 12 months	None	S3–S4 or minor nonconformities	S1–S2 or major or critical nonconformities
F7	Relevant changes since the last audit	None	Minor changes	New model, supplier, purpose, data or autonomy
F8	Economic materiality (recurring cost or declared value)	Low according to the C2 threshold	Medium	High
F9	Time since the last audit	Less than 12 months	12–24 months	More than 24 months or never

Company adjustments to the table (if any) and reason: _____.

4.2 Score per unit

Score = F1 + F2 + … + F9 (from 9 to 27). **Priority**: **High** 21–27, or forced priority · **Medium** 15–20 · **Low** 9–14.

No.	F1	F2	F3	F4	F5	F6	F7	F8	F9	Score	Forced priority (Yes · No)	Priority	Required coverage
U01												High · Medium · Low	
U03													
***(illustrative example)* U01**	2	3	1	3	2	2	3	2	3	21	No	High	In-depth continuity audit this year

In a spreadsheet, with the factors in columns B to J and the forced priority in column L:

- Score (K): `=SUM(B2:J2)`
- Priority (M): `=IF(OR(L2="Yes",K2>=21),"High",IF(K2>=15,"Medium","Low"))`

Indicative coverage by priority (38 §5.2):

Priority	Coverage
High	In-depth continuity audit at least annually.
Medium	Continuity audit at least every two years; included in thematic audits.
Low	By sampling in thematic audits or the framework audit; at least every three years.

Framework processes, suppliers and themes are not scored with this table: processes are covered by the annual framework audit and suppliers according to their N1–N3 level (38 §4).

05

Engagement plan for the year

5.1 Coverage by block

Block (38 §5.3)	Coverage rule	Planned engagements	Is the rule met? (Yes · No)
Enterprise *gate* audits	100 % of the Enterprise *gates* planned in T01		
Lite *gate* audits	Sample in 21 §10.3		
Continuity audits	High-priority systems and the Medium ones due by rotation		
Framework audit	Annual, including the declaration of application (P61)		
Value audit	At least once a year before C5 (43 §12)		
Thematic audits	Between one and three a year		
Suppliers	N3 at least annually; selected N2		

Block (38 §5.3)	Coverage rule	Planned engagements	Is the rule met? (Yes · No)
Follow-up	100 % of open major and critical nonconformities		
Reserve	10–20 % of capacity		

5.2 Engagements

Code	Type	Unit (No.)	Objective and scope	Criteria	Quarter	Lead auditor	Supporting experts	Estimated hours	Priorit
AUD-AAAA-NNN	*Gate* · Continuity · Framework · Thematic · Supplier · Value · Follow-up			Documents 21, 22, standards	Q1 · Q2 · Q3 · Q4				
(illustrative example) **AUD-2027-004**	Continuity	U01	Controls of the enquiries assistant over the last twelve months: monitoring, human oversight, incidents, value and cost (38 §6.3)	R6.nn in document 21; P24; P25	Q2	Lead AI auditor	Offensive security specialist	160	High

The AUD-AAAA-NNN code is the one proposed in 38 §9.1 and is kept in the working papers (P59) and in the report (P60). *Gate* audits receive a code when the *gate* is requested.

06

Capacity and resources

Measure	Value	Guidance
Hours available from AI Auditors in the year		Net of training (F6 profile, document 31 §6.2), holidays and other tasks.
Hours of external experts contracted		
Hours allocated to engagements (sum of 5.2)		
Reserve for unplanned engagements		Hours and percentage of capacity (10–20 %).
Difference		Available − allocated − reserve. If negative, there is a limitation (section 7).
High-priority units not covered		Number and list.
Rotation of lead auditors		Enterprise systems audited by the same auditor for more than [three] consecutive years (38 §3.1).

07

Approval of the plan and limitations

Field	Content	Guidance
Coverage limitations		High- or Medium-priority units not audited within the required period, and reason.
Board committee decision on the limitations		Increases resources · Accepts the risk, with reason.
Approving body		Board committee.
Approval date		DD-MM-AAAA.
Reference of the minutes		
Report of the plan to the board		Date of the meeting at which it is reported.

08

Monitoring of completion

It is presented to the board committee every quarter (38 §5.3). Overdue actions are escalated in accordance with 30 §8.2 and appear in this report (38 §10).

Quarter	Planned engagements	Completed (final report)	In progress	Postponed (reason)	Unplanned added	Degree of completion	Hours used	Nonconfor outcomes
Q1						%		
Q2						%		
Q3						%		
Q4						%		

Degree of completion = completed engagements ÷ engagements planned to date × 100. In a spreadsheet: `=IF(B2=0,"",C2/B2)`.

Amendment to the plan	Date	Reason	Engagement affected	Approved by
		S1 incident · Request · Change of priority · Capacity		

09

Quality criteria

#	Check	Status
1	The universe includes all systems in T02, the use cases with *gates* in the year, the N2 and N3 suppliers and the framework processes.	Met · Not met · Not applicable · Pending
2	Each system has the nine factors scored with data as at the cut-off date, and forced priority is applied where appropriate.	
3	All High-priority systems have an engagement in the year or appear as an approved limitation.	

#	Check	Status
4	The framework audit, including the declaration of application, and the value audit are planned before C5.	
5	The *gate* coverage rules are met (100 % Enterprise; Lite sample in 21 §10.3).	
6	There is a capacity reserve of between 10 % and 20 %.	
7	No lead auditor is assigned an engagement with an incompatibility (30 §5, I-10 and I-11) or exceeds the recommended rotation.	
8	The plan is approved by the board committee and its completion is reported every quarter.	

Question D6.10 in document 11 (framework audit in the last 12 months) is evidenced by the completion of this plan.

10

Approval and verification

Function	Role in SEVEN-G	Name and position	Date	Signature or reference
Prepares	Head of AI audit (internal audit)			
Provides the universe data	AI Office			
Reviews quality	Internal audit quality review			
Approves	Board committee			

Segregation of duties: the AI Office provides the data, but does not decide what is audited or score the units; no area that sponsors use cases approves the plan.

11

Version control

Completed document

Version	Date	Author	Changes

Template

Version	Date	Changes
0.1	19-09-2026	First version. Applies the audit universe, priority factors, coverage rules, and approval and monitoring in 38 §5, with spreadsheet formulas.

External sources cited

Links to the official or primary source, checked before publication. Always verify the version in force on the date of use.

ISO/IEC 42001:2023 Information technology — Artificial intelligence — Management system · https://www.iso.org/standard/42001 · ISO/IEC (JTC 1/SC 42) · 18-12-2023